# Network Hardening Scenario

You are a security analyst working for a social media organization. The organization recently experienced a major data breach, which compromised the safety of their customers’ personal information, such as names and addresses. Your organization wants to implement strong network hardening practices that can be performed consistently to prevent attacks and breaches in the future.

After inspecting the organization’s network, you discover four major vulnerabilities. The four vulnerabilities are as follows:

1. The organization’s employees' share passwords.
2. The admin password for the database is set to the default.
3. The firewalls do not have rules in place to filter traffic coming in and out of the network.
4. Multifactor authentication (MFA) is not used.

If no action is taken to address these vulnerabilities, the organization is at risk of experiencing another data breach or other attacks in the future.

In this activity, you will write a security risk assessment to analyze the incident and explain what methods can be used to further secure the network.

---

## Security risk assessment report

**Part 1: Select up to three hardening tools and methods to implement**

**1. Password Management and Access Controls**

Introduce individual employee accounts and strong password policies to prevent employees from sharing passwords. Replace the database administrator's default password with a unique, strong password and restrict access to sensitive systems based on each employee's responsibilities.

**2. Multifactor Authentication (MFA)**

Implement multifactor authentication across employee accounts, particularly those with administrative privileges, to provide an additional layer of protection against unauthorised access.

**3. Firewall Configuration and Network Hardening**

Configure firewall rules to filter incoming and outgoing network traffic. Disable unused ports and services, implement port filtering and regularly review firewall configurations to reduce potential entry points for attackers.

**Part 2: Explain your recommendations**

## 1. Password Management and Access Controls

Introducing individual employee accounts and strong password policies reduces the risk of unauthorised access caused by shared or compromised credentials. Each employee should have their own login details, making it easier to monitor account activity and identify suspicious behaviour.

The default database administrator password should be replaced immediately with a unique, strong password. Access privileges should also follow the principle of least privilege, ensuring employees and administrators only have access to the systems and information required for their roles.

These controls should be established initially and reviewed regularly, particularly when employees change roles or leave the organisation. Password policies should also be reviewed in line with current security guidance and organisational requirements.

## 2. Multifactor Authentication (MFA)

Multifactor authentication adds another layer of security by requiring users to provide additional verification when accessing an account. For example, after entering a password, an employee may be required to approve a login through an authentication application.

This helps protect accounts even if a password has been stolen or compromised. MFA is particularly important for administrator accounts and systems containing sensitive customer information.

MFA should be implemented across the organisation and maintained regularly to ensure authentication methods remain secure. Employees should also be encouraged to report unexpected authentication requests, as these could indicate an attempt to access their accounts without permission.

## 3. Firewall Configuration and Network Hardening

Firewall rules should be configured to monitor and control incoming and outgoing network traffic. This helps prevent unauthorised connections and restricts potentially harmful traffic from reaching the organisation's internal network.

Unused ports and services should be disabled to reduce the number of potential entry points available to attackers. Port filtering can also be used to restrict network traffic to approved ports and services, reducing the risk of unauthorised access.

Firewall configurations should be reviewed and updated regularly, particularly following security incidents or changes to the network. Additional DDoS protection may also be required to help identify and mitigate unusually high volumes of malicious traffic.

Together, these measures reduce the organisation's exposure to network-based attacks and help protect sensitive customer information from future breaches.